

PROJECT 2- BUILD AND SECURE THE AUTH0-BACKEND AI APPLICATION

Introduction:

Build and Secure the Auth0-Backed AI Application focuses on building an AI chat application with secure authentication and authorization using Auth0. The project involves setting up an Auth0 tenant, registering applications, and configuring the required callback URLs, grant types, and CORS settings.

The project also implements OAuth 2.0 with PKCE, custom API scopes, and JWT verification to control access to different levels of application resources. In addition, TOTP-based Multi-Factor Authentication (MFA), Brute-Force Protection, and Suspicious IP Throttling are configured to improve the security of user authentication.

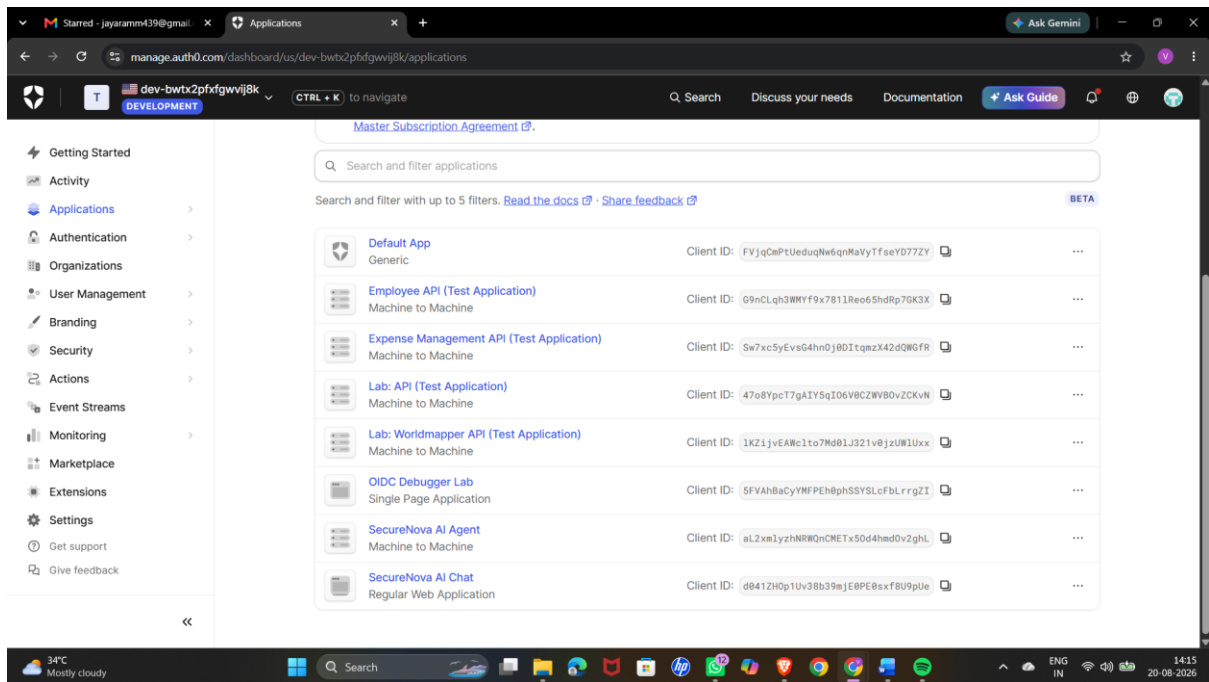
Another important part of the project is credential rotation, where a short-lived Machine-to-Machine token is tested to ensure that an expired token cannot be reused. Finally, an Auth0 post-login Action is implemented to add a custom agent_id claim to the ID token, along with SSO configuration to allow secure authentication across registered applications.

Overall, this project demonstrates how Auth0 can be used to build a secure AI application by combining authentication, authorization, token security, MFA, attack protection, and identity management.

STEP-1: Creating the Required Applications

Description:

In this step, we created two applications in the Auth0 dashboard. The first application was created as a Regular Web Application for the AI chat application, while the second application was created as a Machine-to-Machine Application for the AI agent. These two applications are required to handle user authentication and secure communication between the backend services.

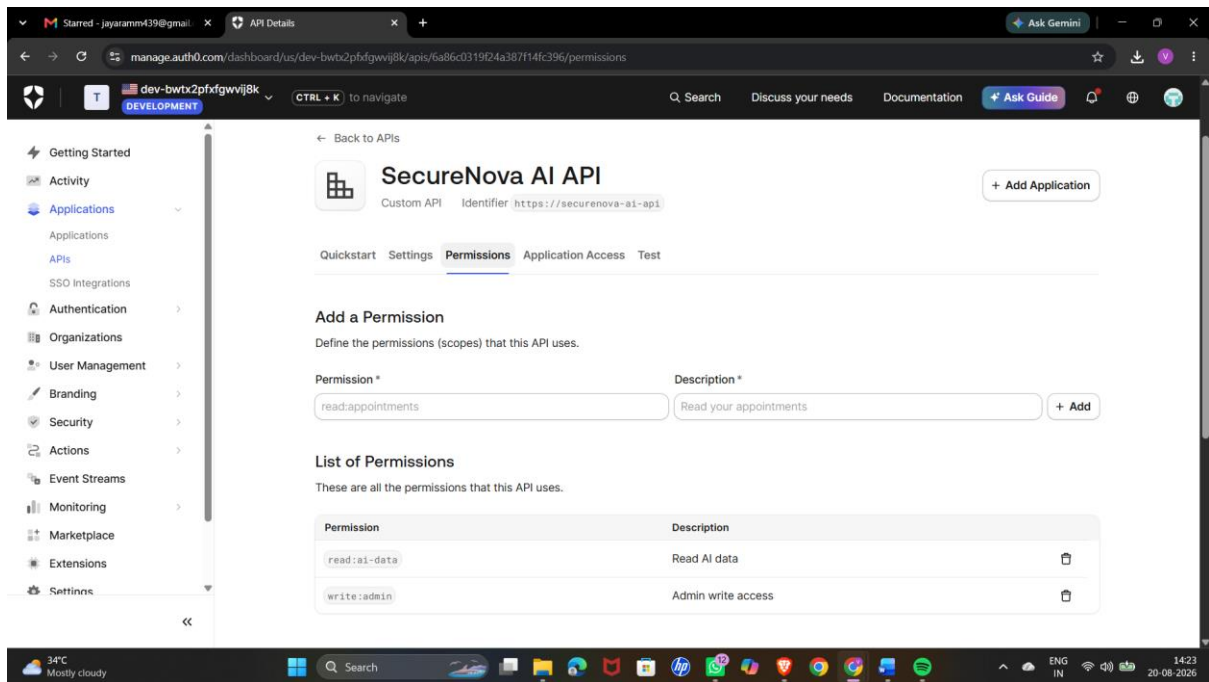


	SecureNova AI Agent Machine to Machine	Client ID: aL2xm1yzhNRWQnCMETx50d4hmd0v2ghL		...
	SecureNova AI Chat Regular Web Application	Client ID: d041ZH0p1Uv38b39mjE0PE8sxf8U9pUe		...

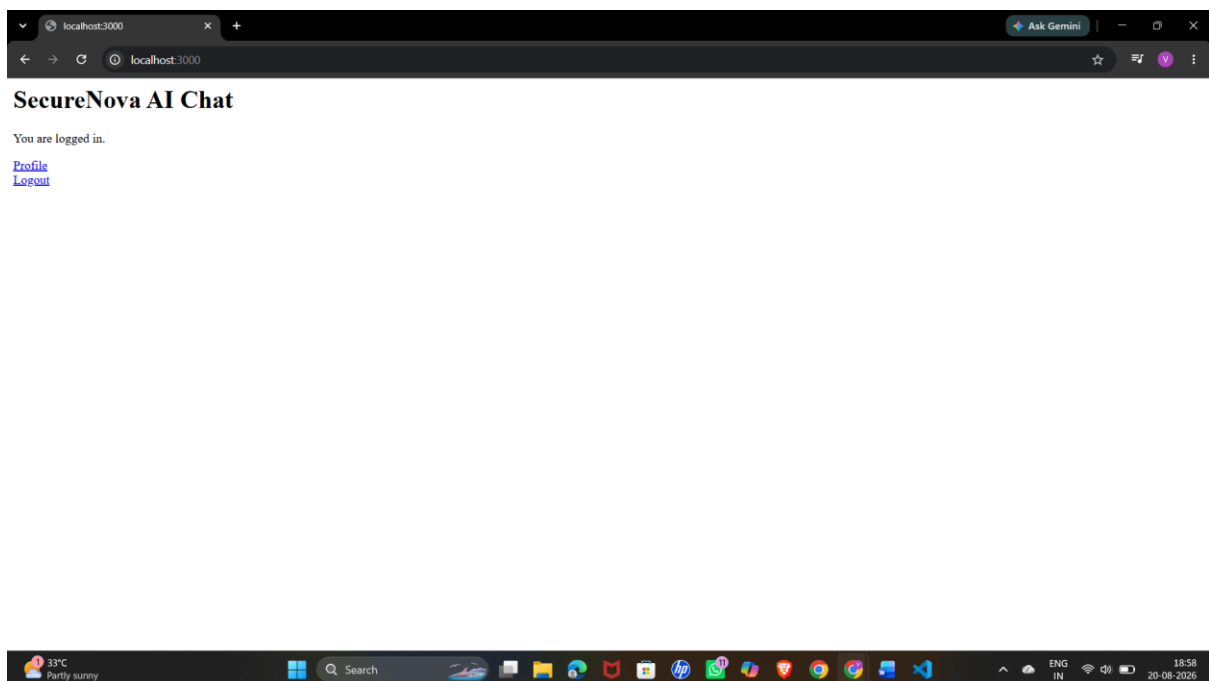
STEP-2: Configuring API Permissions and Scopes

Description:

In this step, we configured the permissions for the SecureNova AI API. The required API scopes, such as reading and writing data, were added so that authenticated applications can access only the resources they are authorized to use.



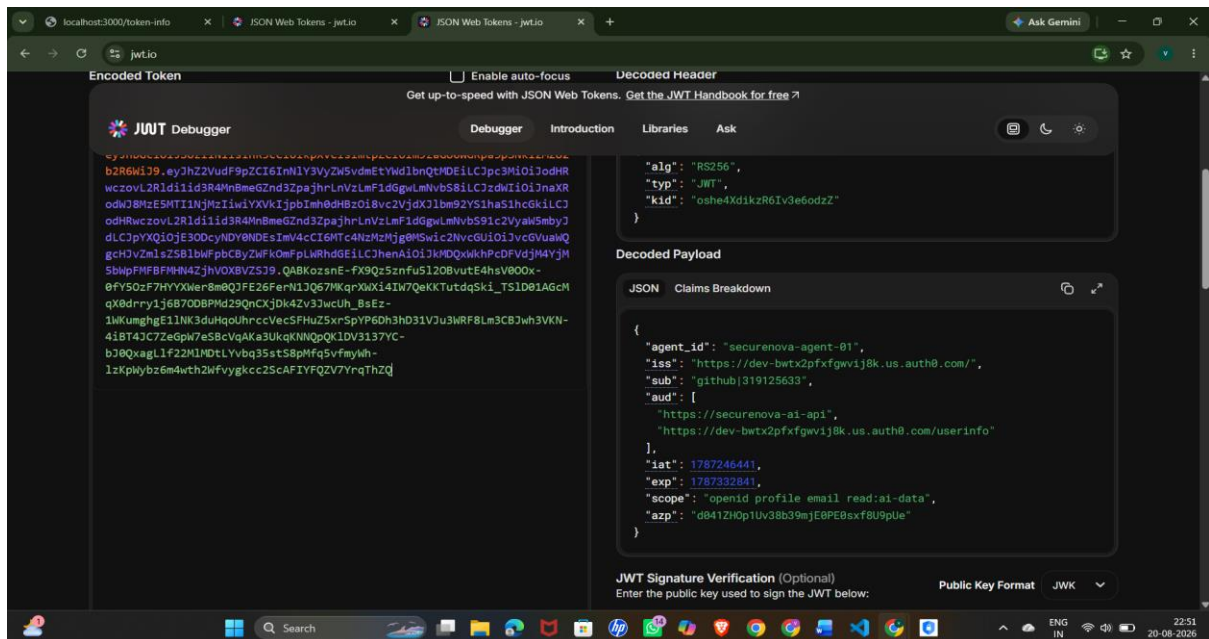
This screenshot shows the SecureNova AI Chat application running in the browser. The application is connected to the Auth0 authentication setup and provides the interface through which users can access the AI service securely.



Step-3: Testing JWT Authentication

Description:

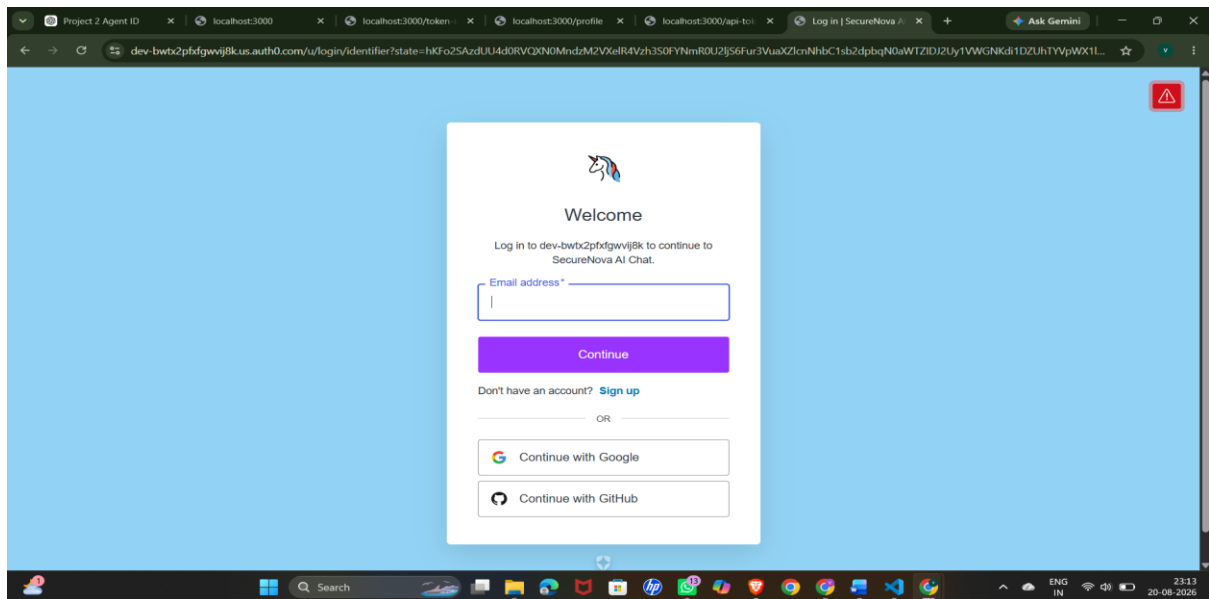
In this step, we generated and inspected a JSON Web Token (JWT) to verify the authentication information provided by Auth0. The decoded token contains details such as the issuer, audience, scope, and other claims. This helped us confirm that the token was generated correctly and contained the required authorization information.



Step-4: Universal Login

Description:

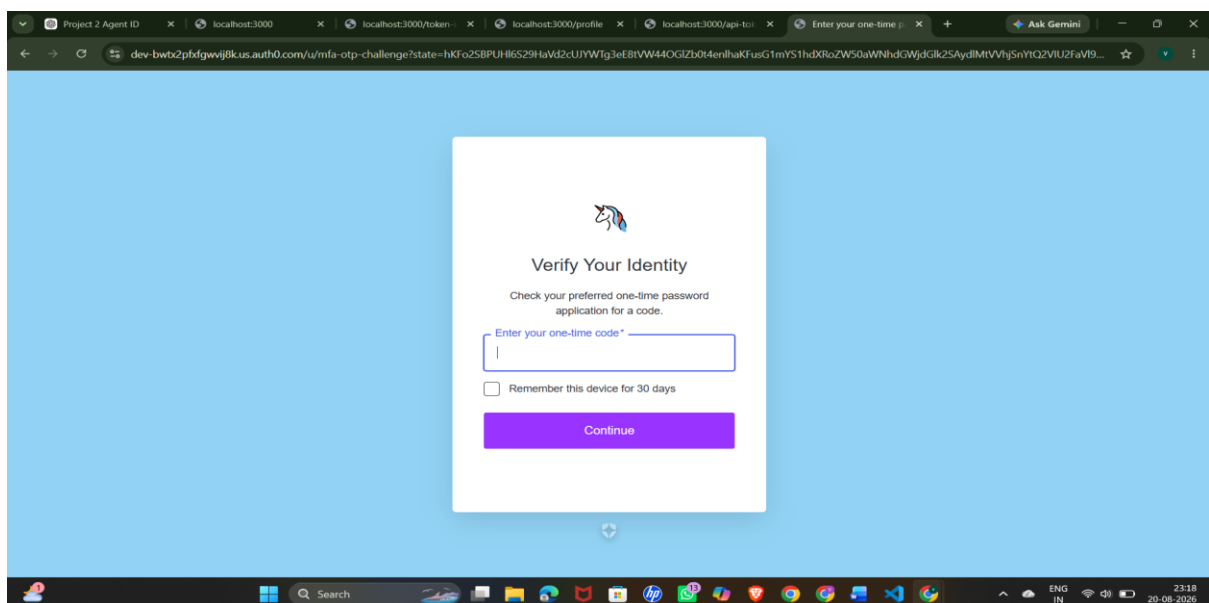
This screenshot shows the Auth0 Universal Login page in the browser with the custom branding applied. It demonstrates that the login page has been configured with the required branding and is ready to provide a customized authentication experience for users.



Step-5: Multi-Factor Authentication (MFA)

Description:

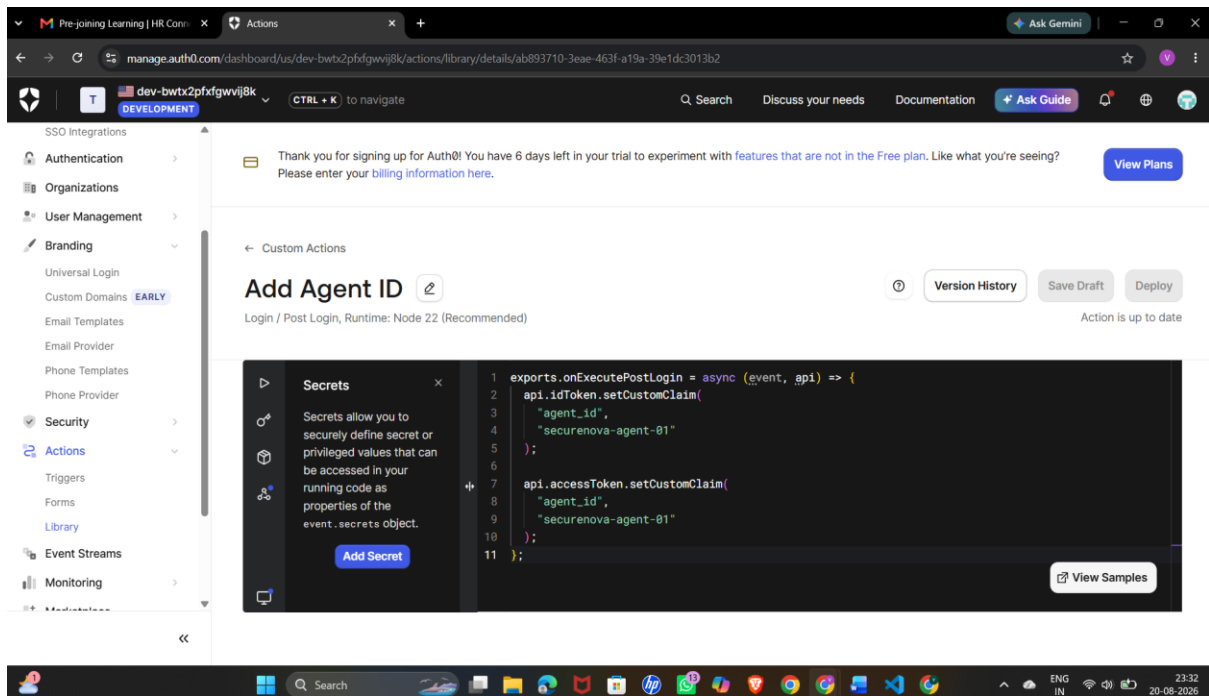
This screenshot shows the Auth0 MFA enrollment screen or TOTP challenge in the browser. It demonstrates that Multi-Factor Authentication has been configured, requiring an additional verification step to improve the security of user authentication.



Step-6: Auth0 Actions: Adding the Agent ID Custom Claim

Description:

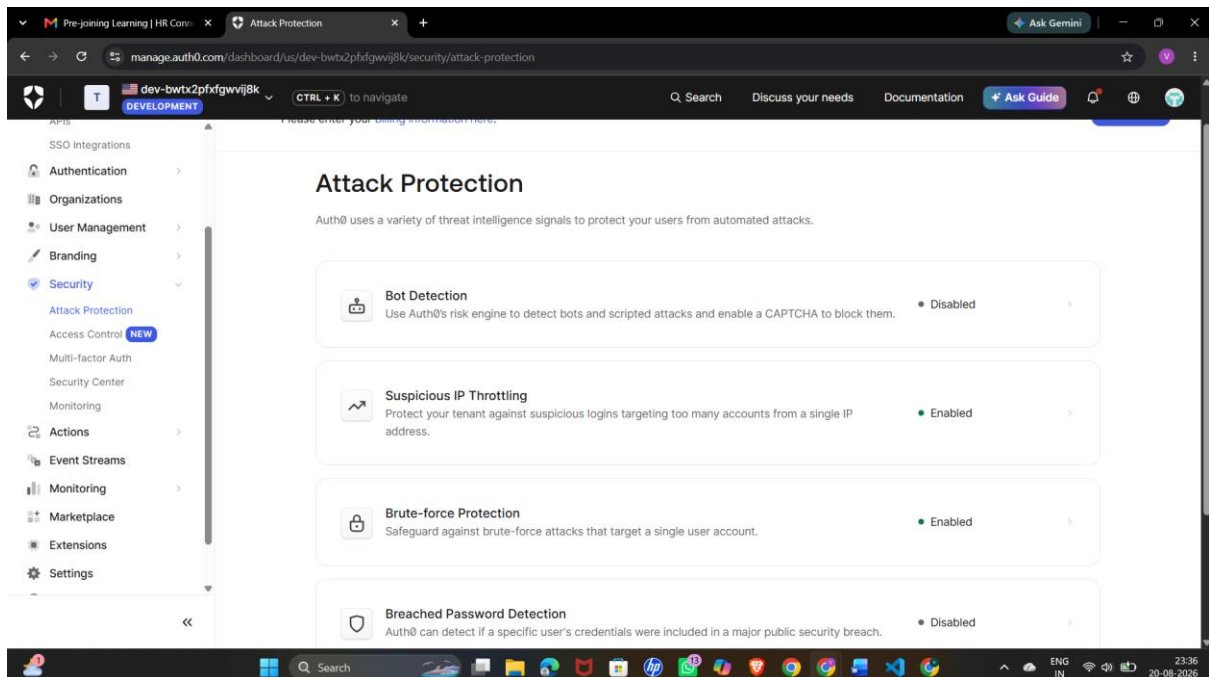
This screenshot shows the Auth0 Actions editor with the post-login Action code. The code adds the agent_id as a custom claim to the user's authentication token after a successful login. This allows the application to identify the AI agent associated with the authenticated user.



Step-7: Enabling Attack Protection

Description:

In this step, we enabled the available attack protection features in Auth0. These security controls help protect the application against common authentication attacks such as brute-force attempts and suspicious IP activity. Enabling these protections strengthens the overall security of the application.




```

PS C:\Users\vijaya.laxmi\OneDrive\Desktop\SecureNova-AI-Chat> python credential_rotation.py
2026-08-21 01:24:22 - Requesting M2M access token...
2026-08-21 01:24:23 - Token request status: 200
2026-08-21 01:24:23 - Access token received.
2026-08-21 01:24:23 - Token lifetime: 60 seconds
2026-08-21 01:24:23 - Token scope: read:ai-data
2026-08-21 01:24:23 - Calling /debug-token with fresh token...
2026-08-21 01:24:24 - First /debug-token response: 200 OK
{"message": "Token accepted", "claims": {"payload": {"iss": "https://dev-bwtx2pfxfgwvjj8k.us.auth0.com/", "sub": "En125kCMQUJORYkiH8e72i5UdE4g9VaN@clients", "aud": "https://securenova-ai-api", "iat": 1787255663, "exp": 1787255723, "scope": "read:ai-data", "gty": "client-credentials", "azp": "En125kCMQUJORYkiH8e72i5UdE4g9VaN"}, "header": {"alg": "RS256", "typ": "JWT", "kid": "oshe4XdikzR6Iv3e6odzZ"}, "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCIsImt0eSI6Im9zaGU0WGRpa3pSNk12MU2b2R6WiJ9.eyJpc3MiOiJodHRwczovL2Rldi1id3R4MnBmeGZnd3ZpaWVzLnVzLnMf1dGgwLmNvbS8iLCJzdWIiOiJFbjBjEjYnNwDTVVFVks9SWWtpSDh1LnZpbnVvKTRTRNOVZhTkBjbGllbnRzIiwiaXVkiOiJodHRwczovL2Rldi1id3ZWN1cmVub3ZhLWFLPFwfaSIsImhhdCI6MTc0NzI1NTYyMmwiZXhwIjoxNzg3MjU1NzIzLCJyZWRwZSI6InJlYWQ6YWktZGF0YSIsImd0eSI6ImNsaWVudC1jcWkZw50aWVscyIsImF6cCI6IkVvMTI1a0NNUVVKT1JZa2l1OGU3MmMk1VWRFNGc5VmFOIn0.C5L8AtBU6-1n8Bn5RAB2HMYDk3mS_yLWtafIGvmsLCZ5otaGTp5MuXv2ntCQpN40wrbqE-yrPu06q7D7VJ8oGsfoVULWwMf-nrMdM2G6uvnChpFCEVOQ2rOrDwtNLOPKGDuoBR1BzOYdrsw0wqdmmy4uUwEDMAAJa9Yg0hs6Sf7ShmqbnM0oF7gicIKgqtmXlEnCwt5VoFo0JWF2d1YaQ3MCRlX8sVoDy0TqKr8u9jMB50q2JzP8QunfZwBi7N1_sMtkYZxog4WjRiIBRgVLXxgGMdnNtAbu0Gp6WPAiQxT511vxxqZoz3lNne6OKtah1KwaHhMmE4tz8PphqU7w"}}
2026-08-21 01:24:24 - Waiting for token to expire...

2026-08-21 01:25:29 - Replaying the same expired token...
2026-08-21 01:25:29 - Replay /debug-token response: 401 Unauthorized
<!DOCTYPE html>

```